

Security Operations guide for email authentication in Microsoft 365

Applies to:  Built-in security features for all cloud mailboxes,  Microsoft Defender for Office 365 Plan 1 and Plan 2,  Microsoft Defender XDR

[Email authentication in Microsoft 365](#) is a critical component of securing communication in your organization. When an email is received in Microsoft 365, the service adds an **Authentication-Results** header. This header shows the results of various email authentication checks, including SPF, DKIM, DMARC, and composite authentication (compauth).

This guide explains common scenarios you might encounter with these results:

- Why a message passed or failed email authentication.
- Whether the email source or email destination is responsible for the result.
- What actions (if any) we recommend for improving email authentication results.

But first, here are a few key definitions:

 Expand table

Acronym	Description
Set up SPF	Sender Policy Framework. Identifies email sources for a domain to help prevent spoofing.
Set up DKIM	DomainKeys Identified Mail. Digitally signs important elements of a message (including the From address header) to verify the message wasn't altered in transit, which helps prevent spoofing.
Use DMARC to validate email	Domain-based Message Authentication, Reporting, and Conformance. Uses SPF and DKIM results to verify alignment between domains in the MAIL FROM address and From address to help prevent spoofing.
Configure trusted ARC sealers	Authenticated Received Chain. Preserve email authentication results across intermediaries that modify messages in transit.
Composite authentication (compauth)	Composite authentication. A proprietary Microsoft 365 technology that combines multiple email authentication signals.
MAIL FROM address	Also known as the 5321.MailFrom address, P1 sender, or envelope sender. Used in the transmission of messages between SMTP email servers. Typically recorded in the Return-Path header field in the message header. Used as the address for non-delivery reports (also known as NDRs or bounce messages).
From address	Also known as the 5322.From address or P2 sender. The email address in the From header field. Shown as the sender's email address in email clients.

 Get the

Email authentication pass scenarios

These scenarios describe messages that **passed email authentication checks** or were accepted (sometimes due to specific configurations). In general, when email authentication passes, no corrective action is needed. However, some scenarios include **cautionary notes** where we recommend configuration improvements to enhance security.

Sender refers to admins in the source organization. **Recipient** refers to admins in the destination organization.

All authentication checks passed

This scenario applies when all standard email authentication checks pass successfully.

- **Header example:** `dmARC=pass` (and typically `spf=pass` and `dkim=pass`).

- **What it means:** All email authentication checks (SPF, DKIM, and DMARC) **succeeded**. This result indicates the message is fully authenticated according to standard email authentication protocols.
- **Who's responsible:** The **sender**.
- **Recommended action:** **None**. Email authentication is correctly configured and working as intended. The recipient can trust the sender domain properly authenticated this message.

Composite authentication passed

This scenario describes how Microsoft 365 can accept a message through composite authentication.

- **Header example:** `compauth=pass` (composite authentication pass).
- **What it means:** The message passed Microsoft 365 composite authentication:
 - DMARC requirements were satisfied: either SPF or DKIM passed *and* the MAIL FROM and From addresses are aligned.
 - Or
 - Microsoft's implicit trust logic identified the message as legitimate. For example, a message might pass composite authentication based on Microsoft's safe sender history or [spooof intelligence](#) indicating the sender is trusted.
- **Who's responsible:** The **sender**.
- **Recommended action:** **None**. The authentication checks succeeded, and the system didn't detect any problems. No changes are needed to SPF or DKIM in this scenario.

DMARC pass with no DMARC policy (no DMARC record)

This scenario covers messages that appear to pass DMARC even though the sender has not published a DMARC record.

- **Header example:** `dmARC=bestguesspass action=none`
- **What it means:** The message passed DMARC **by default** because the sender's domain has **no published DMARC record**. When a domain has no DMARC policy, destination email servers can't fail the message on DMARC. Effectively, the DMARC check doesn't apply. `DMARC=bestguesspass action=none` means if the domain had a valid DMARC record, the DMARC check for the message would pass.
- **Who's responsible:** The **sender**.
- **Recommended action:** **The sender should publish a DMARC record** for their domain. Although the message was accepted, the absence of a DMARC policy isn't a good sign. We recommend that the domain owner sets up a DMARC TXT record to enforce a DMARC policy (`p=quarantine` or `p=reject`) for messages that fail DMARC validation. For more information, see [Syntax for DMARC TXT records](#).

ARC-validated (complex routing scenarios)

This scenario applies to messages accepted through ARC validation in forwarding or other complex routing paths.

- **Header example:** `compauth=pass reason=130` (composite authentication passed due to ARC).
- **What it means:** The message passed authentication due to an **Authenticated Received Chain (ARC)** override. This result typically occurs in complex mail routing or email forwarding scenarios. If an intermediate mail server modifies the message and causes SPF or DKIM to fail, a trusted ARC signature informs Microsoft 365 that the original authentication is valid. In this

case, the system accepted the message based on the valid ARC chain, even though direct SPF or DKIM checks might fail.

- **Who's responsible:** The **Sender (original sender or intermediary)**. There's no misconfiguration. An intermediary who uses ARC processed the message.
- **Recommended action:** **No direct action required** if this scenario is expected (for example, the message was processed by a known service that implements ARC). If you operate a non-Microsoft intermediary service, add ARC headers and verify receiving servers (like Microsoft 365) trust your ARC signatures. This configuration allows inbound messages to pass compauth via ARC.

① Note

In mail forwarding scenarios where the forwarding service is another Microsoft 365 organization, you don't need to configure **trusted ARC sealers for microsoft.com**. ARC signatures are automatically trusted by receiving Microsoft 365 organizations when the message passes validation.

Message delivered due to allow entries for spoofed senders in the Tenant Allow/Block List

This scenario explains why a spoofed message can still be delivered when the recipient organization explicitly allows it.

- **What it means:** The message bypassed normal authentication failure actions because [allow entries for spoofed senders exist in the Tenant Allow/Block List](#). In Microsoft 365, an allow entry for spoofed senders can override failures. Even when email authentication checks normally fail, the message is allowed due to this explicit trust configuration.
- **Header example:** `compauth=fail reason=000` (but an organization policy allowed the message: **Tenant Allow/Block List spoof allowed**).
- **Who's responsible:** The **recipient**. Admins in the recipient's organization configured an allow entry for spoofing in the Tenant Allow/Block list for this specific [domain pair syntax for spoofed sender entries](#). The **sender** should resolve authentication issues to avoid deliverability problems with *other* recipients.
- **Recommended action:** Recipient administrators can check the **All Overrides** section on the [Email entity page](#) to confirm whether a Tenant Allow/Block List override is involved. These messages contain **Allowed by organization policy: Tenant Allow/Block List spoof allowed**.

Generally, **there's no immediate action** for these messages, since they're intentionally allowed. However, it's good practice for admins to **periodically review allow entries for spoofed senders** to ensure only necessary senders are allowed. Overusing the Tenant Allow/Block List allows delivery of (possibly malicious) messages that would normally fail authentication checks.

Authenticated via PTR (reverse DNS) alignment

This scenario describes fallback authentication based on reverse DNS (PTR) information when standard checks are inconclusive.

- **Header example:** `compauth=pass` with codes like `reason=116` or `reason=111` to indicate PTR record use.
- **What it means:** The message passed authentication **based on PTR (reverse DNS) validation** as a fallback. In some cases when SPF and DKIM checks don't yield a conclusive pass, Microsoft 365 can look at the sender's PTR record. If the sending server's IP address has a PTR record (reverse DNS) that matches the domain in the message's **From** address, the system might treat the message as authenticated.

- **Who's responsible:** The **sender**. The sender's email server was verified via PTR record in DNS. This result usually means SPF and DKIM weren't configured correctly, and the system resorted to PTR lookup.
- **Recommended action:** The sender should **ensure SPF and DKIM are configured properly** for their domain. A correct reverse DNS (PTR) record that maps the sending domain to the sending IP address is good, but it isn't a substitute for DMARC alignment. Senders need to treat PTR pass as an indicator to improve their SPF and DKIM configuration. There's no action for the recipient, other than notifying senders when they notice this result.

Email authentication failure scenarios

These scenarios cover **failed authentication checks** or other conditions where the message is marked as not authenticated. Failing an authentication check doesn't always mean the message was rejected. Some failures result in the message being quarantined or delivered with warnings. The following scenarios describe why the failure occurred, who needs to address it, and how to fix the underlying issue.

Sender refers to admins in the source organization. **Recipient** refers to admins in the destination organization.

DMARC Failed (Message Rejected or Quarantined)

This scenario explains how to interpret a DMARC failure that leads to quarantine or rejection of the message.

- **Header example:** `dmARC=fail action=quarantine (or action=reject);` often accompanied by `compauth=fail` with a code (for example, `reason=000`, `reason=001`, or `reason=601`).
- **What it means:** **DMARC validation failed** for the message. This result means:
 - SPF or DKIM didn't pass with alignment for the From address domain.

And

 - The DMARC record of the From address domain contains a `p=quarantine` or `p=reject` policy.

As a result, Microsoft 365 marked the message for the specified policy action: deliver to the Junk Email folder, quarantine, or reject.

- **Who's responsible:** The **sender** or the **recipient**. The failure is due to the sender's domain not passing DMARC or the recipient's [configuration for integrating non-Microsoft security services with Microsoft 365](#) that caused DMARC to fail.

While senders are responsible for correctly configuring SPF, DKIM, and DMARC for their domain, authentication failures can sometimes result from issues in the recipient's organization. For example:

- The recipient's organization uses a non-Microsoft filtering service between the internet and Microsoft 365 without configuring [Enhanced Filtering for Connectors](#). SPF validation might fail when Microsoft 365 receives the message.
- If the non-Microsoft filtering service modifies the message before delivery, DKIM might fail, even though the sender's DKIM record is configured correctly.

Therefore, it's important to distinguish between the verdict at the point of initial receipt (MX record) vs. the verdict when the message reaches the recipient's mailbox.

- **Recommended action:**
 - The **sender needs to fix their email authentication configuration**. Specifically, the sender needs to do the following steps:

- Ensure their **SPF record** includes all legitimate source IP addresses for email from the domain.
- Set up **DKIM** for the domain and verify the signatures are correctly applied to outgoing mail.
- Verify that SPF or DKIM (or both) pass and are also **aligned** with the From address domain as required by DMARC.
- Verify the DMARC record syntax and the DMARC policy. For example, `p=quarantine` or `p=reject`.
- The **recipient needs to fix their complex mail routing configuration**. Specifically, the recipient needs to do the following steps:
 - Configure [Enhanced Filtering for Connectors](#)
 - If available, configure [trusted ARC sealers](#) to override failures caused by message modification in transit.
 - Consider using Microsoft 365 to apply message modifications (footers, disclaimers, subject, etc.) instead of non-Microsoft services.

SPF check failed

This scenario helps you diagnose messages that fail SPF evaluation.

- **Header example:** `spf=fail` or `spf=softfail`. Watch for `spf=temperror` indicating transient DNS issues or `spf=permerror` indicating SPF configuration issues.
- **What it means:** One of the following possibilities:
 - The sending server's IP address is **not authorized** by the domain's SPF record, so SPF returned *fail*.
 - The SPF check couldn't complete properly. For example, a DNS lookup problem (`spf=temperror`) or too many redirects (`spf=permerror`).

An SPF fail without a DMARC pass also results in a DMARC fail.

- **Who's responsible:** The **sender**. The problem lies with the sender domain's SPF record configuration or their sending server setup.
- **Recommended action:** The sender should **update and fix the domain's SPF record**:
 - Verify **all legitimate source IP addresses** for the domain are included in the SPF record.
 - If DMARC fails due to domain misalignment (the MAIL FROM address domain differs from the From address domain), you can fix it by doing one or both of the following steps:
 - Align the domains used in the MAIL FROM and From addresses.
 - Set up DKIM signing of outgoing messages using a domain that matches the From address domain. DMARC requires either SPF or DKIM validation, not both.
 - `spf=temperror` generally indicates the recipient had a problem resolving the SPF record (for example, transient DNS issues). The sender should verify the DNS servers for their domain are healthy and reachable. If the time-to-Live (TTL) value is too low and causes frequent timeouts, consider increasing the TTL to **at least one hour**.
 - `spf=permerror` typically indicates an issue with the SPF record itself, including [troubleshooting SPF TXT records that require more than 10 DNS lookups](#). Simplify the SPF record by removing unnecessary `include:` statements and correcting any syntax errors.

Resolving SPF issues means messages are more likely to pass DMARC authentication. Recipients should notify senders about SPF failures and the recommend actions to fix the issues.

DKIM Check Failed (No key for signature)

This scenario covers DKIM failures caused by missing or mismatched public keys in DNS.

- **Header example:** `dkim=fail` (no key for signature) if the public key was missing.
- **What it means:** One of the following possibilities:

- There was a DKIM signature, but the recipient couldn't find a matching **public key in DNS** (no key).

Or

- The key didn't match the signature (the signature couldn't be verified).

- **Who's responsible:** The **sender**. The sender's domain has a broken DKIM setup:

- A public key isn't present in the DKIM CNAME or TXT record in DNS.

Or

- There's a DNS issue on the sender's side or the receiver's side.

- **Recommended action:** The sender should **correct DKIM set up for their domain** by doing the following steps:

- **Publish the DKIM public key in DNS.** Verify the DKIM CNAME or TXT record contains a valid selector (for example, `selector._domainkey.contoso.com`) that matches the private key used to sign the messages.
- **If the key is published, a timeout likely occurred when Microsoft 365 tried to query the record.** Verify the time-to-Live (TTL) value is set to **at least one hour**.

Tip

Align the domain in the DKIM record for DMARC by using the same domain or subdomain in the DKIM signature's `d=` field as the domain in the From address. This requirement often means working with non-Microsoft services to publish the appropriate public key as described in [DKIM signing of mail from your custom domain at other email services](#).

Once DKIM is properly configured and aligned, recipients see `dkim=pass` for your messages, which also helps the messages pass DMARC.

DKIM failed after modification (Signature didn't verify)

This scenario explains DKIM failures caused by header changes after signing.

- **Header example:** `dkim=fail` (Signature didn't verify).
- **What it means:** The message contained a **valid DKIM signature**, but the message failed DKIM verification because a header included in the DKIM signature was **modified in transit after being signed**. This modification typically occurs when an intermediary (for example, a mailing list, forwarding service, or security appliance) alters a signed header (for example, **Subject**, **From**, or **To**) after the DKIM signature was originally applied. The `h=` value in the **DKIM-Signature** identifies the headers included in the original hash. Modifying any of these headers results in DKIM failure.
- **Who's responsible:** The **sender** or the **intermediary** who altered the message headers. The original sender correctly DKIM signed the message, but an intermediary might be responsible for the broken DKIM signature.
- **Recommended action:** Don't make changes to headers after DKIM signing a message:
 - **Senders:** Verify the signed headers remain unchanged from the moment the message is DKIM-signed until it leaves your environment.
 - **Intermediaries:** Allow customers to configure your service as a [trusted ARC sealer](#) to override DKIM failures caused by message modification in transit.

DKIM failed after modification (Body hash failed)

This scenario covers DKIM failures caused by message body changes after signing.

- **Header example:** `dkim=fail` (body hash fail).

- **What it means:** The message contained a **valid DKIM signature**, but the message failed DKIM verification because the message body was **modified in transit after being signed**. This modification typically occurs when an intermediary (for example, a mailing list, forwarding service, or security appliance) alters the message body content after the DKIM signature was originally applied. The result is the hash calculated by the receiving email system doesn't match the hash in the DKIM signature, so DKIM check fails.
- **Who's responsible:** The **sender** or the **intermediary** that altered the message. The original sender correctly DKIM signed the message, but an intermediary might be responsible for the broken DKIM signature.
- **Recommended action:** Ensure no unintended changes are made to the email content after signing:
 - **Senders:** Do the following steps:
 - Verify the signed headers remain unchanged from the moment the message is DKIM-signed until it leaves your environment.
 - Consider using Microsoft 365 to apply message modifications (footers, disclaimers, subject, etc.) instead of non-Microsoft services.
 - **Intermediaries:** Allow customers to configure your service as a [trusted ARC sealer](#) to override DKIM failures caused by message modification in transit.

Quick reference table for email authentication scenarios

The following table summarizes the email authentication scenarios, the recommended solutions, and links to relevant articles for further reading.

Sender refers to admins of the sending domain. **Recipient** refers to the admins of the receiving organization.

 Expand table

Scenario	Solution	Learn reference
All authentication checks pass (SPF, DKIM, and DMARC all pass)	No action needed. Authentication is completely successful.	Anti-spam message headers in Microsoft 365
Composite authentication pass (compauth=pass)	No action needed. The message was identified as legitimate by compauth. We recommend publishing missing SPF, DKIM, or DMARC records in DNS for explicit verification.	Email authentication in Microsoft 365
DMARC bestguesspass, no policy (no DMARC record)	Sender should publish a DMARC record for the domain.	Use DMARC to validate email
ARC validated (non-Microsoft service trusted via ARC)	No action needed (if message modification by a non-Microsoft service is expected). Ensure non-Microsoft services use ARC.	Configure trusted ARC sealers
Allowed by Tenant Allow/Block List (allowed by organization policy: Tenant Allow/Block List spoof allowed)	No immediate action required. Admins should periodically review allow entries for spoofed senders.	View entries for spoofed senders in the Tenant Allow/Block List
Authenticated via PTR record (reverse DNS lookup)	Sender should configure SPF or DKIM (don't rely on PTR lookup).	Set up SPF identify valid email sources for your Microsoft 365 domain
DMARC Failed (policy quarantine or reject)	Sender to ensure: • SPF or DKIM pass. • MAIL FROM domain or DKIM signing domain is aligned with the From domain. Recipient to configure Enhanced Filtering for Connectors and ARC in complex mail	Use DMARC to validate email Enhanced Filtering for Connectors Configure trusted ARC sealers

Scenario	Solution	Learn reference
	routing scenarios (intermediary services). Recipient to consider shifting message modifications (footers, disclaimers, subject, etc.) to Microsoft 365 to prevent DKIM failures.	Considerations for integrating non-Microsoft security services with Microsoft 365
SPF check failed	Sender to update SPF record (include all source IP addresses and fix errors).	Set up SPF identify valid email sources for your Microsoft 365 domain
DKIM none	Sender should configure DKIM signing using the From address domain.	How to use DKIM for email in your custom domain
DKIM check failed (no key for signature)	Sender should correct DKIM configuration for the domain (publish the DKIM public key).	Set up DKIM
DKIM broken by modification (signature didn't verify or body hash failed)	Configure intermediary services as trusted ARC sealers Recipient to consider shifting message modifications (footers, disclaimers, subject, etc.) to Microsoft 365 to prevent DKIM failures.	Configure trusted ARC sealers

Best practices and tips

Use the following best practices to strengthen and maintain email authentication.

- **Implement SPF, DKIM, and DMARC:** These technologies complement each other and provide defense-in-depth. Anything less leaves gaps in protection.
- **Maintain DNS records:** Keep SPF records up to date with all your email sources. Rotate and manage DKIM keys as needed and monitor your DMARC reports to identify authentication failures.
- **Monitor authentication results:** Regularly check **Authentication-Results** headers or use tools/reports (for example, the Microsoft 365 [spooof intelligence insight](#)) to see how incoming messages are doing. This activity can reveal partners who didn't set up SPF/DKIM or if your own message are failing authentication.
- **Use ARC for relay scenarios:** If your organization does mail forwarding or uses non-Microsoft services that modify messages, consider configuring **trusted ARC sealers** in Microsoft 365. ARC can help preserve authentication and avoid false failures when messages transit through intermediaries.
- **Be cautious with allowlists:** Rely on standard authentication results whenever possible rather than organization allow entries. Allow entries should be exceptions, and should be checked periodically to remove unnecessary entries.
- **Stay Informed:** Follow these resources:
 - [Microsoft Defender for Office 365 Blog](#)
 - [Exchange Team Blog](#)
 - [What's new in Microsoft Defender for Office 365](#)
 - [The Microsoft 365 Message center](#).

Note: The author created this article with assistance from AI. [Learn more](#)

Last updated on 06/15/2026